System Risk Assessment — Customer Portal and Booking API

Larkspur Logistics, Inc. · System Risk Assessment · SRA-2026-01 v2.3

Field	Value
Document id	SRA-2026-01
Version	2.3
Classification	INTERNAL — CONFIDENTIAL (fictitious)
System	Customer Portal and Booking API
Owner team	Digital Channels Engineering
Assessment date	2026-06-05
Next review	2026-12-05
Assessor	Security Operations (SecOps), with Digital Channels Engineering
Exposure	internet-facing
Data classification	Restricted

1. Purpose and scope

This assessment records the architecture, software inventory, exposure and controls of the Customer Portal and Booking API as deployed on the assessment date, so that SecOps can correlate newly disclosed vulnerabilities with what the system actually runs, and so that the Owner Team has an agreed baseline for change. It covers the production environment in the Rotterdam data centre and the DMZ in front of it. The staging environment shares the design but is reachable only from the engineering network and is covered by its own change record.

2. System overview

The Customer Portal is the public web application through which Larkspur's customers create bookings, track shipments, download documents and manage their accounts. The Booking API behind it is the same capability for partner integrations (freight forwarders and customer ERP systems) using OAuth2 client credentials. About 18,000 customer users and 140 partner integrations use the system; it handles roughly 2.1 million requests per day with peaks at the start of each working day in Europe and East Asia.

The system processes personal data of customer contacts (names, business e-mail addresses, phone numbers), commercial data (rates, volumes, consignee details) and payment references. Card data is never stored: payments are tokenised by the external payment provider and only the provider's token and the last four digits are retained. Under the data classification standard the system is rated Restricted because of the volume of customer personal data and the commercial sensitivity of booking and rate information. Availability tier is Tier 1 (24x7, four-hour recovery objective).

Authentication for customers and partners is delegated to the company's Keycloak identity provider (OpenID Connect for the portal, OAuth2 client credentials for the API). Administrative access to every host is through the management bastion with multi-factor authentication.

3. Architecture and hosts

Inbound traffic terminates on a pair of Citrix NetScaler ADC appliances in the DMZ, which provide TLS termination, the web application firewall policy, rate limiting and load balancing. Behind the ADCs, two NGINX Plus hosts serve the portal's static assets and reverse-proxy API traffic to the Booking API. The Booking API is a Spring MVC application packaged as a WAR and deployed on Apache Tomcat across three application hosts on the internal segment. State lives in a PostgreSQL primary with a streaming replica, and Redis holds sessions and short-lived rate-limit counters.

Certificates for the internal hops are issued by the company CA. The application hosts run a certificate enrolment agent that renews host certificates over the Certificate Management Protocol (CMP) against the CA, using a locally built OpenSSL 3.5 toolchain because the distribution's OpenSSL lacks the CMP client features the agent needs.

3.1 Host inventory

Hostname	IP address	Zone	Role	Operating system
edge-adc-01.dmz.corp.example	203.0.113.10	DMZ	NetScaler ADC (active)	NetScaler 14.1
edge-adc-02.dmz.corp.example	203.0.113.11	DMZ	NetScaler ADC (standby)	NetScaler 14.1
portal-web-01.dmz.corp.example	203.0.113.21	DMZ	NGINX Plus reverse proxy	Ubuntu 24.04 LTS
portal-web-02.dmz.corp.example	203.0.113.22	DMZ	NGINX Plus reverse proxy	Ubuntu 24.04 LTS
booking-api-01.corp.example	198.51.100.31	Internal	Tomcat application server	RHEL 9.5
booking-api-02.corp.example	198.51.100.32	Internal	Tomcat application server	RHEL 9.5
booking-api-03.corp.example	198.51.100.33	Internal	Tomcat application server	RHEL 9.5
sso-01.corp.example	198.51.100.41	Internal	Keycloak identity provider	RHEL 9.5
sso-02.corp.example	198.51.100.42	Internal	Keycloak identity provider	RHEL 9.5
portal-db-01.corp.example	198.51.100.51	Internal	PostgreSQL primary	RHEL 9.5
portal-db-02.corp.example	198.51.100.52	Internal	PostgreSQL streaming replica	RHEL 9.5
portal-cache-01.corp.example	198.51.100.55	Internal	Redis session and rate-limit store	RHEL 9.5
bastion-01.mgmt.corp.example	192.0.2.5	Management	SSH bastion (MFA)	Ubuntu 24.04 LTS

4. Software bill of materials

The components below were confirmed from package manifests and running processes during the assessment. Versions are as deployed on the assessment date.

Component	Vendor / project	Version	Role in the system	Deployed on
Citrix NetScaler ADC	Citrix (Cloud Software Group)	14.1-72.18	Edge load balancer, TLS termination, WAF	edge-adc-01, edge-adc-02
NGINX Plus	F5	R35	Reverse proxy and static content for the portal	portal-web-01, portal-web-02
Apache Tomcat	Apache Software Foundation	10.1.55	Servlet container for the Booking API	booking-api-01, booking-api-02, booking-api-03

Component	Vendor / project	Version	Role in the system	Deployed on
Spring Framework	Broadcom (VMware Tanzu)	6.2.15	Application framework of the Booking API (Spring MVC)	booking-api-01, booking-api-02, booking-api-03
Keycloak	Keycloak project (Red Hat sponsored)	26.2.5	Identity provider for customers, partners and staff	sso-01, sso-02
OpenSSL	OpenSSL project	3.5.4	TLS and CMP client library for the certificate enrolment agent	booking-api-01, booking-api-02, booking-api-03
PostgreSQL	PostgreSQL Global Development Group	17.4	Primary database (bookings, accounts, Keycloak schema)	portal-db-01, portal-db-02
Redis	Redis Ltd	7.4.2	Session store and rate-limit counters	portal-cache-01

4.1 Component notes

Citrix NetScaler ADC 14.1-72.18

The ADC pair terminates all customer and partner TLS, enforces the WAF policy (OWASP core rule set profile tuned for the portal), applies per-client rate limits on the API and load-balances to the NGINX Plus hosts. The Gateway feature set is licensed but not enabled: no VPN or ICA proxy virtual servers are configured. Firmware is build 14.1-72.18, applied in March 2026; the vendor had published a newer 14.1 build by the assessment date, which finding F-2026-013 tracks. Management access is restricted to the management network and the SecOps jump host.

NGINX Plus R35

NGINX Plus R35 serves the portal's static bundle and proxies /api traffic to the Booking API pool with active health checks. The configuration uses several map directives with regular expression matching to derive routing and logging variables from request headers, which is the standard pattern in the portal's configuration templates. The hosts run Ubuntu 24.04 with unattended security updates for the operating system; NGINX Plus itself is upgraded manually with each F5 release.

Apache Tomcat 10.1.55

Tomcat 10.1.55 hosts the Booking API WAR. The container is run under a dedicated service account with the manager and host-manager applications removed. Authentication is not performed by Tomcat: the application validates OAuth2 bearer tokens issued by Keycloak, and no Tomcat realm, DIGEST or BASIC authenticator is configured in any context. The HTTP connector listens only on the internal segment and accepts traffic from the NGINX Plus hosts.

Spring Framework 6.2.15

The Booking API is a Spring Boot 3.5 application on Spring Framework 6.2.15. It is a REST service: controllers return JSON and no server-side view technology (JSP, Thymeleaf, XSLT) is configured, and there is no catch-all request mapping. Spring Expression Language is used in method-security annotations with the default evaluation context. The application is built on the CI/CD platform and promoted through staging by the Owner Team.

Keycloak 26.2.5

Keycloak 26.2.5 runs as a two-node cluster with its own PostgreSQL schema on the portal database. The customer realm has self-service registration and the forgot-password (reset-credentials) flow enabled, with e-mail verification; the staff realm federates to the corporate directory and requires MFA. The admin console is reachable only from the management network. Keycloak is shared with the Collaboration Suite and the Data and Analytics Platform, which use the staff realm.

OpenSSL 3.5.4

A locally built OpenSSL 3.5.4 under /opt/larkspur/openssl provides the CMP client used by the certificate enrolment agent to renew host certificates from the internal CA every 30 days. The agent pins the CA's server certificate. This build is separate from the distribution's OpenSSL and is not picked up by the operating system's patch process; it is rebuilt by the Owner Team.

PostgreSQL 17.4

PostgreSQL 17.4 with streaming replication to the replica, TLS between application and database, and role separation between the application, Keycloak and reporting users. Backups are described in Appendix B.

Redis 7.4.2

A single Redis 7.4.2 instance holds short-lived session data and rate-limit counters. It is reachable only from the application hosts; it is not configured with TLS (finding F-2026-012) and runs with a password set through the application's secret store.

5. Network exposure

The system is internet-facing: the portal and the Booking API are reachable from any network on TCP 443 through the NetScaler ADC pair. No other service is exposed to the internet. The DMZ hosts can reach only the Booking API pool on the internal segment; the internal hosts have no route to the internet except through the egress proxy for the payment provider and the e-mail relay.

The legacy partner endpoint /partner/v1 still accepts TLS 1.0 and 1.1 for two partners whose integration has not been migrated; this is finding F-2026-011. All other listeners require TLS 1.2 or 1.3.

5.1 Exposed endpoints

Port / protocol	Service	Reachable from	Authentication
443/tcp	Customer Portal (HTTPS)	Internet	Keycloak OIDC (customers)
443/tcp	Booking API /api/v2 (HTTPS)	Internet	OAuth2 client credentials (partners)
443/tcp	Legacy partner endpoint /partner/v1	Internet (two partner IP ranges)	mutual TLS + API key
8443/tcp	Keycloak admin console	Management network	Staff realm
5432/tcp	PostgreSQL	Internal segment (application hosts)	SCRAM + TLS
6379/tcp	Redis	Internal segment (application hosts)	Password
22/tcp	SSH	Management bastion only	Key + MFA at the bastion

6. Security controls

Control	Status	Last verified	Notes
Web application firewall (NetScaler AppFW	In place	2026-05-28	Blocking mode; tuned exclusions for the booking form. Does not protect the ADC itself.
Network segmentation DMZ / internal / management	In place	2026-05-20	Firewall rules reviewed quarterly.
Multi-factor authentication for administrative access	In place	2026-05-20	Bastion and Keycloak staff realm.
TLS 1.2+ on all listeners	Partial	2026-06-01	Exception on /partner/v1 (F-2026-011).
Weekly authenticated vulnerability scan	In place	2026-06-01	Scanner covers hosts; the NetScaler appliances are scanned unauthenticated.
Centralised logging to the SIEM	In place	2026-05-20	ADC
Rate limiting on the Booking API	In place	2026-05-28	Per client id
Secrets in the central secret store	In place	2026-05-20	Database and Redis credentials; no secrets in configuration files.

7. Open findings

Id	Severity	Finding	Owner	Due
F-2026-011	Medium	TLS 1.0 and 1.1 still accepted on the legacy partner endpoint /partner/v1 for two partners.	Digital Channels Engineering	2026-09-30
F-2026-012	Low	Redis traffic on the internal segment is not encrypted.	Digital Channels Engineering	2026-12-31
F-2026-013	Medium	NetScaler firmware build 14.1-72.18 is behind the vendor's current 14.1 build; upgrade window to be scheduled with the CAB.	Digital Channels Engineering	2026-09-15

8. Ownership and contacts

Role	Name	Contact
Owner Team lead	Tomas Berglund	tomas.berglund@larkspur-logistics.example
Technical lead (application)	Mara Lindqvist	mara.lindqvist@larkspur-logistics.example
Platform contact (ADC and NGINX)	Joost van der Meer	joost.vandermeer@larkspur-logistics.example
SecOps liaison	Priya Nandakumar	secops@larkspur-logistics.example
24x7 on-call	Digital Channels rota	pager alias dc-oncall

Digital Channels Engineering owns the application, the NGINX Plus configuration and the Tomcat hosts. The NetScaler appliances are operated by Digital Channels with firmware changes executed by the Network team under a joint change record. Keycloak is owned by Digital Channels on behalf of all consuming systems.

9. Assessment history

Date	Version	Summary
2024-06-14	1.0	Initial assessment after the portal re-platform.
2025-06-20	2.0	Keycloak replaces the in-house login; NetScaler ADC replaces the previous load balancer.

Date	Version	Summary
2025-12-02	2.2	Interim review after the payment tokenisation change.
2026-06-05	2.3	Annual review; three findings open; firmware lag noted.

Appendix A. Service and port matrix

Host	Port	Service	Listens on	Purpose
edge-adc-01/02	443	HTTPS vServer	203.0.113.10-11	Portal and API ingress
edge-adc-01/02	3010	NetScaler management	192.0.2.0/24 only	Appliance administration
portal-web-01/02	443	NGINX Plus	203.0.113.21-22	Static content and API proxy
portal-web-01/02	8080	NGINX Plus API	127.0.0.1	Health and metrics
booking-api-01..03	8443	Tomcat HTTPS	198.51.100.31-33	Booking API
sso-01/02	8443	Keycloak	198.51.100.41-42	OIDC / OAuth2
portal-db-01/02	5432	PostgreSQL	198.51.100.51-52	Database
portal-cache-01	6379	Redis	198.51.100.55	Sessions and rate limits

Appendix B. Backup, recovery and change management

Backups: PostgreSQL uses streaming replication to portal-db-02 and a nightly base backup with continuous WAL archiving to the object store in the secondary data centre; the recovery point objective is 15 minutes and the recovery time objective four hours, last exercised on 2026-04-22. Redis data is not backed up (sessions are re-created on login). NetScaler and NGINX configurations are exported nightly to the configuration repository.

Change management: routine changes go through the weekly CAB; emergency security changes use the emergency change procedure with retrospective CAB review. Application releases are deployed by the Owner Team's pipeline on the CI/CD platform, with a canary on booking-api-01 for one hour before the remaining hosts. Firmware upgrades on the ADC pair are performed on the standby node first with a failover test.

Appendix C. Change log

Date	Change	Approved by
2026-03-14	NetScaler firmware upgraded to 14.1-72.18 on both appliances.	CAB
2026-04-02	Tomcat upgraded to 10.1.55 and Spring Framework to 6.2.15 with release 2026.4 of the Booking API.	CAB
2026-04-30	Keycloak upgraded to 26.2.5.	CAB
2026-05-12	Certificate enrolment agent rebuilt against OpenSSL 3.5.4.	Owner Team
2026-05-27	NGINX Plus upgraded to R35 on both proxy hosts.	CAB